MDM GRC READINESS & CONTROL ASSURANCE CASE STUDY

MDM-D05

Control Requirements and Framework Crosswalk

Deliverable 5 of 15 in a portfolio case study on readiness and control assurance for mobile access to Microsoft 365 at a fictional 850-employee Saudi financing company. Cross-references to other deliverables use their MDM-D numbers.

Prepared by

Ali Fathi Aldhabiki

Cybersecurity Governance, Risk & Compliance (GRC)

linkedin.com/in/ali-aldhabiki-a74354212 | ali.f.aldhabiki@outlook.com

Notice

The organization is fictional. No Microsoft Intune or Entra ID tenant was configured; all evidence, test results and ratings are simulated.

Control Requirements and Framework Crosswalk

MDM-D05

Control Register

Control ID

MDM-CTL-001

Field	Details
Control Title	Device Passcode and Automatic Lock
Related Risk	MDM-RSK-001
Control Objective	Prevent unauthorized access to corporate mobile devices when lost, stolen or left unattended.
Control Statement	All in-scope company-owned mobile devices must require a passcode meeting the approved strength requirements. Devices must automatically lock after a defined period of inactivity and require authentication to unlock.
Control Function	Preventive
Control Nature	Technical
Design Status	Defined — pending platform-specific configuration mapping and validation.
Control Owner	IT Operations Manager
Control Operator	IT Operations Team
Minimum Passcode Length	At least 6 digits for a PIN, or 6 characters for a password.
Passcode Complexity	Simple passcodes must be blocked, including repeated or sequential PINs.
Automatic Lock Timeout	No more than 5 minutes of inactivity.
Authentication After Lock	Authentication must be required immediately to unlock, with no grace period.
Supporting Reference	SAMA CSF 3.3.8, control considerations 5 and 6(a). Specific configuration values are defined for this project.

Control ID

MDM-CTL-002

Field	Details
Control Title	Corporate Data Transfer Protection on BYOD
Related Risk	MDM-RSK-002
Control Objective	Prevent corporate data leakage to personal or unapproved destinations when using BYOD devices.
Control Statement	In-scope work applications on BYOD devices must enforce restrictions that prevent corporate data from being saved, shared, or copied and pasted to personal apps, accounts, storage locations, or other unapproved destinations. Transfers between approved corporate destinations may be permitted only where the required data protection remains enforced.
Control Function	Preventive
Control Nature	Technical
Design Status	Defined - pending platform-specific configuration mapping and validation.
Control Owner	IT Operations Manager
Control Operator	IT Operations Team
Corporate Data Storage	Corporate data must be saved only to approved corporate storage locations where the required protection remains enforced. Saving copies to personal accounts or unprotected local storage must be blocked.
App-to-App Data Sharing	Sharing or opening corporate data in another app must be restricted to approved work apps using corporate accounts, with the required data protection maintained. Transfers to personal accounts or unapproved apps must be blocked.
Copy and Paste Restrictions	Copying and pasting corporate data must be restricted to approved work apps and corporate accounts where the required protection remains enforced. Pasting corporate data into personal or unapproved

Field	Details
	destinations must be blocked.
Supporting Reference	SAMA CSF 3.3.10, control considerations 4(c) and 4(d), supporting business/personal information separation and mobile application governance. Specific data transfer restrictions are defined for this project.

Control ID

MDM-CTL-003

Field	Details
Control Title	Compliance-Based Access for Corporate Mobile Devices
Related Risk	MDM-RSK-003
Control Objective	Prevent non-compliant corporate mobile devices from accessing in-scope corporate services and exposing corporate data.
Control Statement	Access to in-scope Microsoft 365 services from company-owned mobile devices must require a compliant device status based on defined security requirements. Non-compliant devices must be denied access. Access may be restored only after remediation and reassessment confirm compliance, subject to other applicable access requirements.
Control Function	Preventive
Control Nature	Technical
Design Status	Defined - pending platform-specific configuration mapping and validation.
Control Owner	IT Operations Manager
Control Operator	IT Operations Team
Compliance Assessment Requirements	In-scope company-owned Android and iOS/iPadOS devices must be assigned applicable compliance policies that assess the approved security baseline, including minimum OS version

Field	Details
	and applicable security update requirements. Platform-specific criteria will be defined in MDM-D07.
Access Enforcement	Conditional Access must require devices to be marked as compliant before granting access to in-scope Microsoft 365 services. Device enrollment alone must not satisfy this requirement.
Unverified Compliance Status	Devices without an assigned compliance policy, or without a valid compliant status, must not satisfy the device compliance requirement for access.
Access Restoration	Access may be restored only after the cause of non-compliance is remediated and reassessment confirms a compliant status, subject to all other applicable access requirements.
Supporting Reference	SAMA CSF 3.3.8, control considerations 1, 2 and 5, supports defining and monitoring infrastructure security standards covering mobile devices. Microsoft Learn: “Device compliance policies in Microsoft Intune” and “How to Require Device Compliance with Conditional Access” support the technical design. The compliance-based access requirement is defined for this project.

Control ID

MDM-CTL-004

Field	Details
Control Title	Access Policy Change Management
Related Risk	MDM-RSK-004
Control Objective	Prevent unintended disruption to authorized mobile access caused by access policy changes and enable controlled recovery if disruption occurs.

Field	Details
Control Statement	Changes to in-scope mobile access policies must undergo documented impact assessment, testing and required approvals before deployment. A rollback plan must be prepared before implementation. Post-implementation verification must confirm that authorized access remains available and required access restrictions remain effective. If the change fails the defined acceptance criteria, recovery must follow the approved rollback procedure.
Control Function	Preventive and Corrective
Control Nature	Administrative
Design Status	Defined - pending validation of change workflow, approval routing and rollback arrangements.
Control Owner	IT Operations Manager
Control Operator	IT Operations Team
Business Approval	Business Owner
Cybersecurity Approval	CISO
Change Authorization	Change Advisory Board (CAB)
Change Impact Assessment	Each change must document its purpose, affected policies, users, device groups and services, expected access outcomes, and potential security and availability impacts.
Pre-Implementation Testing	Changes must be tested before deployment using representative access scenarios. Testing must confirm that authorized access is allowed and prohibited access remains blocked. Results and acceptance criteria must be documented.
Change Approvals	Business Owner approval and CISO cybersecurity approval must be obtained before submission to CAB. CAB authorization must be recorded before deployment. These approvals are dependencies on the corporate change management process.

Field	Details
Deployment and Communication	Affected teams must be informed of the planned change, implementation window and support arrangements. Deployment must begin with a limited scope where feasible, with results checked before broader rollout.
Rollback Preparation	Before deployment, the previous approved configuration must be retained and rollback steps, activation criteria, the responsible operator and the rollback decision authority must be documented.
Post-Implementation Verification	After deployment, IT Operations must verify that authorized access remains available and required access restrictions remain effective. Results must be recorded. Changes that fail acceptance criteria must follow the approved rollback procedure, with recovery verified.
Supporting Reference	SAMA CSF 3.3.7, control considerations 4(a)–4(f) and 4(i), supports impact assessment, security testing, approvals, post-implementation review, and fallback and rollback procedures. CISO approval responsibility and deployment details are defined for this project.

Control ID

MDM-CTL-005

Field	Details
Control Title	Intune Administrative Access Management
Related Risk	MDM-RSK-005
Control Objective	Reduce the risk of unauthorized changes to centralized device security settings by restricting administrative access to approved responsibilities and reviewing continued access needs.
Control Statement	Administrative access to Microsoft Intune must be formally approved and restricted to the permissions and management scope required for assigned responsibilities. Access must be attributable to individual administrators and

Field	Details
	independently reviewed at least every three months and upon role changes. Unnecessary or inappropriate access must be removed or adjusted promptly, and access must be revoked as part of the departure process.
Control Function	Preventive and Detective
Control Nature	Administrative and Technical
Design Status	Defined - pending validation of administrative role mappings, scope restrictions and access review arrangements.
Control Owner	CISO
Control Operator	IT Operations Manager / IT Operations Team
Access Authorization	Requests for Intune administrative access must document the business need, required permissions and management scope. The IT Operations Manager must approve team members' requests; requests for the manager's own access must be approved by the CISO. No individual may approve their own access.
Least Privilege and Scope	Administrative permissions must be limited to approved responsibilities and the devices or groups each administrator is authorized to manage. Broad administrative access must require documented justification and CISO approval. Platform-specific role and scope mappings must be validated before implementation.
Individual Accountability	Administrative access must use individually assigned accounts so that actions can be attributed to a specific administrator. Shared administrative accounts must not be used for routine administration.
Periodic and Event-Driven Reviews	Administrative access must be reviewed at least every three months and upon role changes or changes in business need. The IT Operations Manager must review team members' access; the

Field	Details
	CISO must review the manager's access. No individual may review their own access.
Access Adjustment and Revocation	Unnecessary or inappropriate permissions identified during reviews must be removed or adjusted promptly. Administrative access must be revoked as part of the departure process without waiting for the next periodic review. Review findings must remain open until the required changes are verified.
Review and Approval Records	Records must identify the administrator, assigned permissions and scope, business justification, approver, reviewer, review date and decision. Required access changes and evidence of their completion must be retained.
Supporting Reference	SAMA CSF 3.3.5, control considerations 4(a), 4(b)(4)–4(b)(7), and 4(f)(1)–4(f)(3), support business-based access restrictions, formal approvals, timely access changes, periodic reviews, audit trails and individual accountability. The quarterly review frequency, approval and review assignments, and restriction on routine shared administrative accounts are project-defined requirements.

Control ID

MDM-CTL-006

Field	Details
Control Title	Employee Device Report Access Control
Related Risk	MDM-RSK-006
Control Objective	Prevent inappropriate internal access to employee device reports by restricting access to authorized individuals with a documented business need.
Control Statement	Employee device reports must be stored in an approved repository with access restricted according to assigned tasks and business need. Read, update and access-management

Field	Details
	permissions must be separately controlled. Broad internal sharing must be prohibited, and access must be reviewed periodically and adjusted when responsibilities or business needs change.
Control Function	Preventive and Detective
Control Nature	Administrative and Technical
Design Status	Defined - pending validation of repository permissions, sharing restrictions and access review arrangements.
Control Owner	IT Operations Manager
Control Operator	IT Operations Team
Approved Storage and Sharing	Employee device reports must be stored in an approved repository. Folder permissions, file permissions and sharing links must restrict access to authorized recipients. Organization-wide links and broadly accessible internal folders must not be used to distribute these reports.
Access Approval and Permission Levels	Access requests must document the required task and permission level. The IT Operations Manager must approve access; requests for the manager's own access must be approved by the CISO. Read access must be used where sufficient. Update and access-management permissions must be separately justified and restricted to designated personnel.
Access Reviews	The IT Operations Manager must review authorized users, permission levels and sharing links at least every three months and when responsibilities or business needs change. The CISO must review the manager's own access, where applicable. No individual may approve or review their own access.
Access Removal and Adjustment	Unnecessary or excessive access must be

Field	Details
	removed or reduced promptly. Access must be revoked as part of the departure process without waiting for the next periodic review. Inappropriate sharing links must be disabled, and completion of required changes must be verified.
Access and Review Records	Records must identify approved users, business justification, permission levels, approvals and review decisions. Evidence must include relevant repository permissions and sharing settings, identified access issues and verification of completed corrections.
Supporting Reference	SAMA CSF 3.3.5, control considerations 4(a) and 4(b)(4)–4(b)(7), support business-based access, formal approvals, timely access changes, periodic reviews and access-request audit trails. Repository and sharing restrictions, permission levels, reviewer assignments and the quarterly review frequency are project-defined requirements.

Control ID

MDM-CTL-007

Field	Details
Control Title	Contractor Offboarding and Access Revocation
Related Risk	MDM-RSK-007
Control Objective	Prevent continued access to corporate resources after contractor departure through timely notification, access revocation and verification.
Control Statement	Each contractor must have a designated internal sponsor and a recorded authorization end date and time. Automated reminders must be sent to the sponsor one month before expiry and weekly thereafter until expiry. Corporate access must be revoked when authorization ends unless an extension is formally approved beforehand. Early departures must trigger urgent notification and

Field	Details
	access revocation at the revised end time. Completion must include verification that access is blocked and documented follow-up on company device recovery and corporate data handling.
Control Function	Preventive and Detective
Control Nature	Administrative and Technical
Design Status	Defined - pending validation of departure notifications, automated reminders, access revocation mechanisms and verification procedures.
Control Owner	IT Operations Manager
Control Operator	Designated Internal Sponsor / IT Operations Team
Contractor Records and Notifications	Each contractor's record must identify the designated internal sponsor, corporate accounts, assigned company devices and authorization end date and time. The sponsor must keep departure details current and immediately notify IT Operations of early departures or changes to the agreed end time.
Automated Reminders and Extensions	IT Operations must configure automated reminders to the sponsor one month before expiry and weekly thereafter until expiry. Extensions must be formally approved by the responsible business manager and recorded before the existing authorization expires. Missing responses or pending extension requests must not delay access revocation.
Access Revocation	IT Operations must disable relevant corporate accounts and remove access to in-scope applications, groups and shared resources when authorization ends. Existing sessions and tokens must be revoked using supported platform mechanisms. Platform-specific steps and timing limitations must be documented and validated

Field	Details
	before implementation.
Verification and Escalation	IT Operations must retain evidence of account disablement, session revocation actions and checks confirming that access to in-scope services is blocked. Account status alone must not be treated as sufficient evidence. Failed or incomplete actions must be immediately escalated to the IT Operations Manager and remain open until effective access removal is verified.
Device Recovery and Corporate Data	The sponsor must coordinate the return of assigned company devices, and IT Operations must record their receipt and handle corporate data according to approved retention and secure removal procedures. Unreturned devices must be escalated for protective action. Access revocation must not wait for device recovery, and a remote removal command must not be treated as completed without confirmation.
Offboarding Records	Records must include the contractor and sponsor identities, authorized end time, notifications, reminders, approved extensions where applicable, affected accounts and devices, revocation timestamps, verification results and outstanding issues. Access removal and device recovery must be tracked separately, with unresolved actions assigned an owner and target completion date.
Supporting Reference	SAMA CSF 3.3.5, control considerations 4(b)(1), 4(b)(3)–4(b)(5), 4(b)(7) and 4(c), support third-party access lifecycle management, initiation by an appointed accountable party, formal approvals, timely access changes, audit trails and automation. The reminder schedule, expiry-based revocation timing, verification steps and device-handling workflow are project-defined requirements.

Control ID

MDM-CTL-008

Field	Details
Control Title	Device Compliance Report Accuracy Verification
Related Risk	MDM-RSK-008
Control Objective	Ensure that device compliance statuses are attributed to the correct devices in reports used for operational follow-up.
Control Statement	Manually compiled device compliance reports must preserve the association between each device identifier and its compliance status. Before reports are released for operational use, device-to-status mappings must be verified against the source records, and any identified mismatches must be corrected.
Control Function	Preventive and Detective
Control Nature	Administrative
Design Status	Defined - pending validation of source report fields, device identification and report review procedures.
Control Owner	IT Operations Manager
Control Operator	IT Operations Team
Source Records and Device Matching	Each report must use an identified source of device compliance records. During compilation, each device identifier must remain associated with its corresponding compliance status. Matching must use an identifier that uniquely distinguishes the device record in the source; employee names or email addresses alone must not be used. The source report and extraction date and time must be recorded.
Independent Report Review	Before each manually compiled device compliance report is released for operational use, an IT Operations team member other than the preparer must verify device-to-status mappings against the source records. Identified mismatches

Field	Details
	must be corrected and rechecked before release.
Review and Correction Records	Review records must identify the report version, preparer, reviewer, review date and outcome. Any mismatches must be documented together with their corrections and the reviewer's confirmation that the corrected mappings agree with the source records. The source records used for verification and evidence of the completed review must be retained.
Supporting Reference	SAMA CSF Section 1.2 provides the information integrity objective. Section 3.2.1.3, control considerations 6(a)–6(c), supports identifying, evaluating and selecting risk-appropriate controls. Device matching, independent pre-release review and correction records are project-defined requirements.

Outstanding Design and Validation Items

The items left open when these controls were designed were carried forward: technical requirements into MDM-D07, access design into MDM-D08, and evidence, testing and findings into MDM-D09 to MDM-D11. Their current status is tracked in MDM-D11. One dependency sits outside this project and remains open here:

Related Control	Outstanding Item	Tracked In	Status
N/A - Enterprise dependency	MFA for user sign-in to mobile services is provided by an enterprise IAM control, not by this project. That control and its owner must be identified, and its coverage of in-scope users, approved apps, corporate devices and BYOD confirmed.	MDM-D08 Section 4.5 and assumption A-06	Open

Framework Crosswalk

Control ID	Framework	Reference	Mapping Rationale	Mapping Limitations
MDM-CTL-001	SAMA CSF v1.0	3.3.8 Infrastructure Security, considerations	Supports including mobile devices within infrastructure	General supporting mapping. The cited provisions do not explicitly prescribe

Control ID	Framework	Reference	Mapping Rationale	Mapping Limitations
		5 and 6(a)	security standards and defining security configuration and access controls. Device passcode and automatic lock requirements address this aspect of mobile device protection.	passcode or automatic lock requirements. The six-digit PIN or six-character password minimum, repeated/sequential PIN restrictions, five-minute maximum inactivity timeout and immediate authentication after lock are project-defined.
MDM-CTL-001	NCA ECC 2:2024	2-6-3-2 — Mobile Devices Security	Device passcode and automatic lock contribute to controlled and restricted use of company-owned mobile devices by limiting unauthorized device access.	General supporting mapping; this control addresses only part of restricted device use. The cited provision does not explicitly prescribe passcodes, automatic locking or their configuration values. ECC is an adopted baseline for this case study.
MDM-CTL-002	SAMA CSF v1.0	3.3.10 Bring Your Own Device, considerations 4(c) and 4(d)	Restrictions on corporate data storage, sharing and copy-and-paste support business/personal information separation and controlled use of approved work applications on BYOD.	Specific transfer restrictions and approved destinations are project-defined; platform mappings remain pending. This mapping covers aspects of 4(c) and 4(d), not all BYOD requirements or compliance with 4(e).
MDM-CTL-002	NCA ECC 2:2024	2-6-3-1 — Mobile Devices	Restrictions on storage, sharing	Partial mapping to the data separation

Control ID	Framework	Reference	Mapping Rationale	Mapping Limitations
		Security	and copy-and-paste to personal or unapproved destinations support separation of corporate information from personal information on BYOD.	requirement only. CTL-002 does not define encryption requirements. Specific transfer restrictions are project-defined, and platform mappings remain pending. ECC is an adopted baseline for this case study.
MDM-CTL-003	SAMA CSF v1.0	3.3.8 Infrastructure Security, considerations 1, 2 and 5	Defining security requirements for company-owned mobile devices and assessing their compliance supports infrastructure security standards and compliance monitoring within the mobile device scope.	The cited provisions do not explicitly require compliance-based access or Microsoft Conditional Access. Access blocking, handling of unverified compliance and restoration conditions are project-defined. Platform criteria and enforcement mappings remain pending in D07–D08.
MDM-CTL-003	NCA ECC 2:2024	2-6-3-2 — Mobile Devices Security	Requiring a valid compliant device status before company-owned mobile devices can access corporate services supports controlled and restricted device use.	General supporting mapping. The provision does not explicitly require device compliance checks or Conditional Access. Compliance criteria, access blocking and restoration conditions are project-defined and require technical validation. ECC is an adopted baseline for

Control ID	Framework	Reference	Mapping Rationale	Mapping Limitations
				this case study.
MDM-CTL-004	SAMA CSF v1.0	3.3.7 Change Management, considerations 4(a)–4(f) and 4(i)	Supports change impact assessment, security testing, business and cybersecurity approvals, CAB authorization, post-implementation review and rollback procedures for mobile access policy changes.	Mapping is limited to the specified change management aspects within the mobile access scope. Assigning cybersecurity approval to the CISO, representative access tests, acceptance criteria and deployment details are project-defined. This control does not establish full coverage of 3.3.7.
MDM-CTL-004	NCA ECC 2:2024	1-6-1 and 1-6-2-2 — Cybersecurity in Information and Technology Project Management	Security impact assessment and pre-deployment verification of mobile access policy settings support integrating cybersecurity requirements into change management and reviewing secure configurations before changes are released.	Partial mapping to cybersecurity integration and pre-release configuration review. The cited provisions do not prescribe the control's approval routing or rollback workflow. Coverage does not extend to all project management, hardening or update requirements. ECC is an adopted baseline for this case study.
MDM-CTL-005	SAMA CSF v1.0	3.3.5, considerations 4(a), 4(b)(4)–4(b)(7) and 4(f)(1)–4(f)(3)	Formal approvals, restricted administrative permissions and scope, timely	Partial mapping: CTL-005 does not address the MFA provisions within 4(f)(1). Quarterly reviews, approval and review

Control ID	Framework	Reference	Mapping Rationale	Mapping Limitations
			access adjustments, periodic reviews, access records and individually assigned accounts support controlled privileged access and individual accountability.	assignments, and the prohibition of routine shared administrative accounts are project-defined. Intune role and scope mappings remain pending.
MDM-CTL-005	NCA ECC 2:2024	2-2-3-3, 2-2-3-4 and 2-2-3-5 — Identity and Access Management	Restricting Intune permissions to assigned responsibilities, preventing self-approval and self-review, and periodically reviewing administrative access support least privilege, segregation of duties and privileged access management.	Mapping covers selected administrative access practices, not all privileged access safeguards. Quarterly frequency and specific role assignments are project-defined. Technical role and scope validation remains pending. ECC is an adopted baseline for this case study.

Control ID	Framework	Reference	Mapping Rationale	Mapping Limitations
MDM-CTL-006	SAMA CSF v1.0	3.3.5, considerations 4(a) and 4(b)(4)–4(b)(7)	Business-need-based report access, formal approvals, timely permission changes, periodic reviews and retained access records support controlled access to employee device reports.	Repository and sharing restrictions, separate permission levels, reviewer assignments and quarterly reviews are project-defined. Mapping covers report access management, not all identity and access management requirements or report accuracy.
MDM-CTL-006	NCA ECC 2:2024	2-2-3-3 and 2-2-3-5 — Identity and Access Management	Restricting report permissions to assigned tasks, separating read, update and access-management permissions, preventing self-approval and self-review, and reviewing access periodically support least privilege, segregation of duties and access rights review.	Specific repository settings, sharing-link restrictions, review assignments and quarterly frequency are project-defined. Technical permission validation remains pending. ECC is an adopted baseline for this case study.
MDM-CTL-007	SAMA CSF v1.0	3.3.5, considerations 4(b)(1), 4(b)(3)–4(b)(5), 4(b)(7) and 4(c)	Designated sponsor notifications, approved extensions, timely access revocation, retained offboarding records and	The reminder schedule, exact authorization expiry timing, session revocation and verification steps, and device recovery workflow are project-defined. Automated reminders support

Control ID	Framework	Reference	Mapping Rationale	Mapping Limitations
			automated reminders support third-party access lifecycle management.	only part of access management automation. Platform mechanisms and timing limitations remain pending validation.
MDM-CTL-007	NCA ECC 2:2024	1-9-5 — Cybersecurity in Human Resources	Revoking contractor access when authorization ends, including early departures, supports immediate review and revocation of personnel access rights upon termination or departure.	Offboarding roles and procedures are project-defined. Mapping covers access revocation only, not all offboarding or data removal requirements. ECC is an adopted baseline for this case study.
MDM-CTL-008	SAMA CSF v1.0	1.2 — Integrity objective; 3.2.1.3, 6(a)–6(c)	Device-to-status verification supports information integrity through a control selected to address the identified reporting risk.	General supporting mapping. Device identifiers, independent review, correction and review records are project-defined, not expressly prescribed by these references.
MDM-CTL-008	NCA ECC 2:2024	2-7 — Objective; 2-7-1 — Data and Information Protection	Defined report preparation and verification requirements support accurate handling and integrity of device	General supporting mapping, not full coverage of 2-7-1. Matching and review procedures are project-defined. ECC is an adopted baseline for this case study.

Control ID	Framework	Reference	Mapping Rationale	Mapping Limitations
			compliance information.	